

# W10D1 - Security assessment

## danix.xyz - valutazione vulnerabilità e possibili rimedi

### Sommario

#### W10D1 - Security assessment

[danix.xyz - valutazione vulnerabilità e possibili rimedi](#)

[Sommario](#)

[Introduzione](#)

[Oggetto del test \(scope\)](#)

[Risultati in breve](#)

[Tecnologie utilizzate](#)

[Risultati](#)

⇒ [Credenziali di accesso a caselle email personali pubblicamente visibili](#)

[Descrizione](#)

[Mitigazione](#)

[Implicazioni](#)

[Allegati](#)

### Introduzione

In questo report valuteremo le eventuali vulnerabilità rilevate sul nostro sito target <https://danix.xyz> ed eventuali azioni di rimedio. La ricerca viene effettuata in buona fede al fine di migliorare la sicurezza del sito.

### Oggetto del test (scope)

li seguenti domini, sono stati aggiunti allo scope dei nostri test.

- <https://danix.xyz>
- <https://git.danix.xyz>

### Risultati in breve

| # | Vulnerabilità riscontrata                                                                  | Criticità | Risolto |
|---|--------------------------------------------------------------------------------------------|-----------|---------|
| 1 | Rilevate credenziali di accesso a indirizzi email personali hardcoded in uno script python | ALTA      | SI      |
|   |                                                                                            |           |         |

### Tecnologie utilizzate

Per questi test abbiamo utilizzato i seguenti software:

- nmap 7.95
- Maltego 4.10.1
- recon-ng 5.1.2

Inoltre abbiamo verificato tramite ricerche web mirate l'accessibilità a risorse ed informazioni che non dovrebbero essere pubblicamente visibili.

## Risultati

### ⇒ Credenziali di accesso a caselle email personali pubblicamente visibili

- Sito interessato
  - <https://git.danix.xyz>

#### Descrizione

Tramite una specifica ricerca su Google è possibile visualizzare un file all'interno di un repository GIT, contenente indirizzi email e app password di due account gmail personali, un attaccante potrebbe utilizzare le credenziali per accedere agli account e impersonare il titolare.

```
48     imapPass = args.pword
49     except Exception as e:
50         raise
51
52     try:
53         imapPort = args.port
54     except Exception as e:
55         raise
56
57
58     # # Enter your imap settings below
59     # imapServer = "imap.gmail.com"
60     # # imapUserName = "danixland@gmail.com"
61     # imapUserName = "it.danilo.macri@gmail.com"
62     # # imapPass = "jxibrnebktqbkhmx"
63     # imapPass = "udykutvueszpxfkd"
64     # imapPort = 993
65     # # displayName = "gmail - danixland"
66     # displayName = "gmail - Danilo Macri"
67
68     # Try to connect to imap server
69     try:
70         server = imaplib.IMAP4_SSL(imapServer, imapPort)
71         server.login(imapUserName, imapPass)
72         status, unread = server.status('INBOX', '(UNSEEN)')
73     except Exception:
74         pass
75
76     if status != 'OK':
77         server_error = 1
78
79     # Retry a couple of times even though we got wrong response from server
80     # # Retry a couple of times even though we got wrong response from server
```

*Uno screenshot della pagina trovata via google dork in cui è possibile vedere le credenziali in chiaro.*

#### Mitigazione

Rimuovere completamente il file da internet potrebbe risultare difficile, sia per la commit history di git che per eventuali altri siti che potrebbero averne fatto una copia (siti come archive.org).

Il primo step è quindi quello di modificare subito i dati di accesso agli account compromessi, revocando le app passwords e sostituendole con la tecnologia oauth dove possibile.

Rimuovere il repository da gitweb potrebbe essere uno step successivo, utile per evitare che il file sia ancora visibile al visitatore occasionale. Questo non impedirà di utilizzare git per gestire il version control del file, ma solo la possibilità di visualizzarlo online.

## Implicazioni

La presenza di credenziali leggibili in chiaro, oltre che creare un rischio per la perdita dei propri account e di tutto quello che ad essi è collegato, ci ha permesso di eseguire tutta una serie di ricerche attorno al sito web che ci hanno permesso di collegare molti profili del proprietario, mappando la sua presenza online.

Negli allegati a questo file possiamo visualizzare una mappa della presenza online del proprietario di questo sito, eseguita con delle semplici ricerche tramite i tool Maltego e recon-ng, oltre che una scansione nmap delle principali porte aperte sul sistema che ospita i siti target, da cui non si evincono vulnerabilità apparenti.

## Allegati

1. [Report Maltego](#) → ./allegati/danix-xyz\_maltego.pdf
2. [Report nmap TCP](#) → ./allegati/danix-xyz\_nmap-TCP.pdf
3. [Report nmap UDP](#) → ./allegati/danix-xyz\_nmap-UDP.pdf
4. [Report recon-ng](#) \*formato html → ./scansioni/danix-xyz\_recon-ng.html

Con questo si conclude la nostra valutazione del sito <https://danix.xyz>.

Alla prossima.

A handwritten signature in black ink, appearing to read 'Danilo' followed by a stylized monogram or set of initials.